

CO2_AT1_SCENERIO_BASED

Nitheesh Kumar

ETHICAL HACKING ITA1416

SIMATS ENGINEERING

ASSESSMENT TOOL I – SCENARIO-BASED ASSESSMENT (HIGH)

Course Name: Ethical Hacking for Secure Networks	Code: ITA1436	CO: CO2
Duration: 90 min Date:	Total Marks:	Reg. No / Name : 192325090/ Nitheesh Kumar K

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.(BL3)

Assessment Tool Weightage: 35%

Instructions: Answer all questions. Each question carries 10 marks.

Scenario 1: A cybersecurity analyst has been assigned to conduct a security assessment for a multinational company. Before performing any active scanning, the analyst collects publicly available information about the target organization. Using tools such as WHOIS, Recon-ng, and online search engines, the analyst gathers domain registration details, IP address ranges, and contact information. The collected data will be used to identify potential attack surfaces and security weaknesses. Questions:

1. Explain how WHOIS can be used during footprinting.

WHOIS is a protocol and database service used to retrieve information about a registered domain name. During footprinting, it helps an analyst collect basic details about the target organization without directly interacting with its systems.

The information obtained through WHOIS includes:

- Domain owner or registrant details (if not privacy-protected)
- Domain registration and expiration dates
- Registrar name
- Name servers (DNS servers)
- Administrative and technical contact information
- Organization name and contact email

Purpose:

This information helps identify domain ownership, infrastructure, and potential points for further investigation during the security assessment.

WHOIS is a protocol and database used to obtain publicly available registration information about a domain name. During the **footprinting** phase of cybersecurity or ethical hacking, WHOIS helps security professionals gather important information about a target organization's website and domain ownership. The information collected is publicly available and is used for reconnaissance before performing security assessments.

WHOIS provides details such as:

- **Domain name** (e.g., example.com)
- **Domain registrar** (the company where the domain is registered)
- **Domain registration date**
- **Domain expiration and renewal date**
- **Domain status**
- **Name servers (DNS servers)**
- **Registrant, administrative, and technical contact details** (if not protected by privacy services)

During footprinting, analysts use WHOIS to identify who owns a domain, when it was registered, and which registrar manages it. The registration and expiration dates help determine how long the organization has owned the domain and whether it is actively maintained. Name server information helps identify the DNS infrastructure, which can be useful for understanding the organization's network setup.

For example, if an ethical hacker performs a WHOIS lookup on a company's domain, they may discover:

- The domain is registered through a specific registrar.
- The domain was created several years ago and expires next year.
- The organization's authoritative name servers are being used.
- Administrative contact information is available (if privacy protection is disabled).

This information can be combined with other footprinting techniques, such as DNS lookup and Google Dorking, to build a profile of the target organization. Security professionals also use WHOIS to verify domain ownership, investigate suspicious websites, detect phishing domains, and identify related infrastructure.

2. What information can Recon-ng gather about a target organization?

Recon-ng is an open-source reconnaissance framework that automates information gathering from public sources.

It can collect:

- Domain and subdomain information
- IP addresses and network ranges
- DNS records
- Employee names and email addresses
- Social media profiles
- Company contact information
- Technology stack and web services
- Leaked credentials (from supported public data sources)
- Hostnames and SSL certificate details

Purpose:

Recon-ng combines data from multiple online sources to create a detailed profile of the target organization, helping identify possible attack surfaces.

Recon-ng is an **Open Source Intelligence (OSINT)** and reconnaissance framework used during the **footprinting** phase of ethical hacking and cybersecurity assessments. It automates the process of collecting publicly available information about a target organization from multiple online sources. Recon-ng uses modules and APIs to gather intelligence in an organized and efficient manner.

Recon-ng can collect the following information about a target organization:

1. Domain Information

- Domain names
- Subdomains
- DNS records
- WHOIS information
- Domain registration details

2. Network Information

- IP addresses
- Network ranges
- Autonomous System Numbers (ASN)
- Name servers
- Host information

3. Employee Information

- Employee names
- Job titles
- Email addresses
- Social media profiles
- Professional profiles from platforms like LinkedIn (where available)

4. Email Information

- Company email addresses
- Email formats (e.g., firstname.lastname@company.com)
- Email leaks from public sources
- Contact information

5. Company Information

- Organization name
- Office locations
- Contact numbers
- Website details
- Business-related public information

6. Social Media Intelligence

- Twitter/X accounts
- GitHub profiles
- Other publicly available social media accounts
- Public posts related to the organization

7. Public Documents

- PDF files
- Word documents
- Excel spreadsheets
- Presentations
- Metadata contained within these documents

3. Why is passive information gathering preferred before active scanning?

Passive information gathering is preferred because it collects information **without directly interacting with the target's systems**.

Advantages:

- Does not generate network traffic to the target.
- Reduces the risk of detection by intrusion detection/prevention systems (IDS/IPS).
- Prevents accidental disruption of business operations.
- Provides valuable background information before conducting active tests.
- Helps plan more focused and efficient active scanning.

Passive information gathering is the process of collecting information about a target **without directly interacting with its systems or network**. It uses publicly available sources such as search engines, WHOIS databases, DNS records, company websites, social media, and public documents. **Active scanning**, on the other hand, involves directly communicating with the target's systems using tools like Nmap, vulnerability scanners, or port scanners to identify open ports, services, and potential vulnerabilities.

Passive information gathering is preferred before active scanning because it is **safe, stealthy, and does not alert the target organization**. Since there is no direct contact with the target's network, the organization's firewalls, intrusion detection systems (IDS), and intrusion prevention systems (IPS) are unlikely to detect the reconnaissance activity. This allows ethical hackers and security professionals to gather valuable intelligence without generating logs or triggering security alerts.

Another important reason is that passive information gathering helps build a **clear profile of the target** before conducting active tests. Information such as domain names, subdomains, IP addresses, DNS records, technologies used, employee details, and publicly available documents can be collected in advance. This information helps security professionals plan targeted and efficient active scanning, reducing unnecessary network traffic and saving time.

Passive techniques also reduce the risk of **disrupting services**. Active scanning sends packets to the target system, which may consume network resources or affect poorly configured systems. By first collecting publicly available information, security professionals can limit active scanning to specific systems that are relevant, minimizing the possibility of causing service interruptions.

Advantages of Passive Information Gathering

- Does not directly interact with the target's systems.
- Avoids detection by firewalls, IDS, and IPS.
- Collects publicly available information legally and ethically.
- Helps identify domains, IP addresses, DNS records, technologies, and employee details.
- Reduces unnecessary network traffic during active scanning.
- Enables better planning and more accurate security assessments.
- Minimizes the risk of disrupting target services.

Conclusion:

Passive reconnaissance is the safest first step in a penetration test because it minimizes risk while providing essential information for identifying potential vulnerabilities.

Scenario 2: A technology startup plans to launch a new cloud-based service in a highly competitive market. To understand industry trends, a security consultant is asked to analyze competitor websites and online presence. The consultant uses tools such as BuiltWith and SimilarWeb to identify technologies, hosting platforms, and traffic patterns. The information collected will help the startup improve its security posture and business strategy. Questions:

1. How does BuiltWith help in competitive intelligence?

BuiltWith is a web technology profiling tool that identifies the technologies used by a website.

It can reveal:

- Web server software (e.g., Apache, Nginx)
- Content Management Systems (CMS) such as WordPress or Drupal
- Programming frameworks and libraries
- Analytics and tracking tools
- E-commerce platforms
- CDN and hosting technologies
- Security technologies such as SSL, WAF, and CDN providers

Purpose:

It helps organizations understand the technology stack used by competitors, allowing them to evaluate industry standards, identify technology trends, and make informed technical decisions.

BuiltWith is a web technology profiling tool used in **competitive intelligence** and **footprinting** to identify the technologies used by a website. It analyzes a website and provides information about its software, frameworks, hosting, analytics, security tools, content management systems (CMS), and other technologies. This helps organizations understand how competitors build and manage their online presence.

During competitive intelligence, BuiltWith allows analysts to examine a competitor's website without directly interacting with their internal systems. It gathers publicly available information about the technologies powering the website, helping businesses compare their own technology stack with that of competitors.

Information Gathered by BuiltWith

BuiltWith can identify:

- **Web server technologies** (Apache, Nginx, IIS)
- **Content Management Systems (CMS)** such as WordPress, Drupal, or Joomla
- **Programming languages and frameworks** (PHP, ASP.NET, React, Angular, etc.)
- **JavaScript libraries** and frontend frameworks
- **Hosting providers** and cloud platforms
- **Analytics tools** (Google Analytics, Adobe Analytics)
- **Advertising and marketing tools**
-

2. What type of information can SimilarWeb provide?

SimilarWeb is a digital intelligence platform that provides insights into a website's online performance and audience.

It provides information such as:

- Estimated website traffic
- Visitor demographics
- Traffic sources (direct, search, social, referral, email)
- Geographic distribution of visitors
- Audience interests and behavior
- Competitor comparisons
- Top referring websites
- Keyword and search traffic analysis
- User engagement metrics (average visit duration, pages per visit, bounce rate)

Purpose:

This information helps organizations understand market trends, customer behavior, and competitor performance.

3. How can competitive intelligence improve cybersecurity planning?

Competitive intelligence supports cybersecurity planning by helping organizations understand industry practices and potential risks.

It can:

- Identify security technologies commonly used by competitors.
- Benchmark security measures against industry standards.
- Detect emerging threats and attack trends within the industry.
- Guide the selection of secure hosting providers and cloud platforms.
- Improve risk assessment by understanding competitors' technology stacks.
- Support better security architecture and investment decisions.
- Enhance incident preparedness by learning from competitors' security practices and public incidents.

Conclusion:

By analyzing competitors' technologies and online presence, organizations can make informed decisions to strengthen their security posture, reduce risks, and remain competitive in the market.

Scenario 3: A financial organization wants to evaluate the security of its public-facing infrastructure. During reconnaissance, an ethical hacker performs DNS enumeration to identify available DNS records. The investigation reveals several subdomains and mail server configurations that were not properly documented. The security team must determine whether this information could be exploited by attackers.

Questions:

1. What is DNS enumeration?

DNS enumeration is the process of collecting information about a target organization's Domain Name System (DNS). It is a reconnaissance technique used to discover publicly available DNS records, subdomains, mail servers, and other network-related information.

Purpose:

It helps security professionals identify an organization's internet-facing assets and detect misconfigurations or undocumented systems that could become attack targets.

2. Which DNS records are commonly collected during reconnaissance?

The commonly collected DNS records include:

- A Record – Maps a domain name to an IPv4 address.
- AAAA Record – Maps a domain name to an IPv6 address.
- MX (Mail Exchange) Record – Identifies the mail servers responsible for receiving emails.
- NS (Name Server) Record – Lists the authoritative DNS servers for the domain.
- CNAME (Canonical Name) Record – Maps one domain or subdomain to another.
- TXT Record – Stores text information such as SPF, DKIM, and domain verification details.
- PTR (Pointer) Record – Used for reverse DNS lookup (IP address to domain name).
- SOA (Start of Authority) Record – Contains administrative information about the DNS zone.

3. How can exposed DNS information create security risks?

Exposed DNS information can create several security risks, including:

- Revealing undocumented subdomains that may contain vulnerable services.
- Exposing mail server configurations, making phishing and email attacks easier.
- Helping attackers map the organization's network infrastructure.
- Identifying public-facing servers that can be targeted for attacks.
- Revealing outdated or misconfigured systems that may contain vulnerabilities.
- Supporting social engineering and reconnaissance by exposing organizational details.
- Enabling attackers to plan more targeted and effective cyberattacks.

Conclusion:

Proper DNS configuration, regular DNS audits, and restricting unnecessary information exposure help reduce reconnaissance opportunities and strengthen an organization's overall security.

Scenario 4: An ethical hacker is conducting a reconnaissance exercise for a client organization. Using advanced search engine operators, the hacker discovers publicly accessible files containing employee directories and configuration documents. Some of these documents reveal details about internal systems. The organization wants to know how such information became publicly accessible.

Questions:**1. What is search engine footprinting?**

Search engine footprinting is the process of using search engines and advanced search techniques to gather publicly available information about a target organization. It helps identify sensitive information, exposed files, websites, and other online resources that may be indexed by search engines.

Purpose:

It is used during reconnaissance to discover information that could reveal potential security weaknesses.

2. How do search operators help locate sensitive information?

Search operators (also called Google Dorks) refine search results to locate specific types of publicly accessible information.

Examples include:

- **site:** – Searches within a specific website or domain.
- **filetype:** – Finds specific file formats such as PDF, DOCX, or XLSX.
- **intitle:** – Searches for keywords in a webpage title.
- **inurl:** – Searches for keywords in a webpage URL.
- **intext:** – Searches for specific text within a webpage.

Purpose:

These operators help identify publicly indexed documents, directories, configuration files, login pages, or other information that may have been unintentionally exposed.

3. What steps should organizations take to protect confidential files?

Organizations should take the following measures:

- Store confidential files in secure, access-controlled locations.
- Configure web servers to prevent sensitive files from being publicly accessible.
- Use authentication and authorization for internal documents.
- Prevent search engines from indexing sensitive content where appropriate (e.g., using robots.txt and noindex directives, while recognizing these are not access controls).
- Regularly audit websites and cloud storage for exposed files.
- Remove unnecessary or outdated documents from public servers.
- Encrypt sensitive data both at rest and in transit.
- Train employees on secure document handling and sharing practices.
- Conduct periodic security assessments and penetration testing to identify exposed information.

Conclusion:

Search engine footprinting can reveal unintentionally exposed information. By implementing proper access controls, secure configurations, and regular audits, organizations can significantly reduce the risk of confidential data being discovered through search engines.

Scenario 5: A company's DNS administrator receives reports that unauthorized users may have accessed DNS information. During an investigation, the security team discovers that the DNS server allows unrestricted zone transfers. As a result, attackers can obtain a complete list of internal and external hosts. The organization needs to secure its DNS infrastructure immediately.

Questions:**1. What is a DNS zone transfer?**

A DNS zone transfer is the process of copying DNS records from a primary (master) DNS server to a secondary (slave) DNS server. It ensures that both DNS servers have the same, up-to-date DNS information for redundancy and reliability.

Purpose:

Zone transfers are intended only for authorized DNS servers to synchronize DNS records.

2. Why is unrestricted zone transfer considered a security risk?

If zone transfers are allowed without restrictions, attackers can obtain a complete copy of the DNS zone.

This creates security risks because attackers can:

- Discover all domain names and subdomains.
- Identify internal and external hosts.
- Learn about mail servers, name servers, and other infrastructure.
- Map the organization's network more easily.
- Identify potential targets for cyberattacks.
- Use the information to plan phishing, reconnaissance, or exploitation activities.

Conclusion:

Unrestricted zone transfers expose valuable network information that should only be shared between trusted DNS servers.

3. How can organizations prevent unauthorized zone transfers?

Organizations should implement the following security measures:

- Restrict zone transfers to authorized secondary DNS servers only.
- Use Access Control Lists (ACLs) to allow transfers only from trusted IP addresses.
- Disable zone transfers if secondary DNS servers are not required.
- Use TSIG (Transaction Signature) authentication to verify authorized DNS servers.
- Regularly audit DNS server configurations and permissions.
- Monitor DNS logs for unauthorized zone transfer attempts.
- Keep DNS server software updated with the latest security patches.
- Perform periodic DNS security assessments.

Conclusion:

By restricting zone transfers, using authentication mechanisms like **TSIG**, and regularly monitoring DNS activity, organizations can protect their DNS infrastructure from unauthorized access and reduce the risk of reconnaissance by attackers.

Code of Conduct:

I Nitheesh Kumar K. – (192325090) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: K Nitheesh Kumar

RUBRICS FOR CALCULATION

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Scenario	20%				
Identification of Key Issues	20%				
Application of Concepts	25%				
Decision Making	20%				
Clarity of Response	15%				

Criteria	Understanding of Scenario	Identification of Key Issues	Application of Concepts	Decision Making	Clarity of Response	Total
Q1						
Q2						
Q3						

CO2_AT1_SCENERIO_BASED						
Q4						
Q5						